COMPTIA SECURITY+ SY0-701 | DOMAIN 5 · SECURITY PROGRAM MANAGEMENT AND OVERSIGHT (20%)

Security+ 5.2 · Risk Management Strategies

Mestre CyberSec · **Lesson 5.2 — Risk Management Strategies** (3:12) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Executive Lesson Summary:** Resposta ao risco: MITIGATE (reduz com control); TRANSFER (passa pra outro — seguro, terceiro); ACCEPT (aceita e assme residual, documentado); AVOID (não faz a atividade).

💡 Key Exam Highlights & Critical Concepts

- MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual.
- AVOID: não faz a atividade — a resposta mais radical

🎯 Exam Tips & Typical CompTIA Scenarios

- 'purchasing cyber insurance'=risk transfer

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 5.2 — Risk Management Strategies)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Risk Mitigation (MITIGATE)

Risk response strategy that reduces the likelihood or impact of a threat by applying security controls; it does not eliminate all risk.

⚠️ ***Exam Trap:*** *Palavras-chave como firewall, MFA, patch e treinamento indicam mitigação. Não confunda com transferência, pois o controle reduz o risco internamente.*

• Risk Transference (TRANSFER)

Risk response strategy that shifts the financial impact of a risk to another party, commonly through insurance, contracts, or third-party outsourcing.

⚠️ ***Exam Trap:*** *Comprar seguro cibernético = TRANSFER. A responsabilidade financeira é repassada, mas o risco operacional pode permanecer.*

• Risk Acceptance (ACCEPT)

Risk response strategy where the organization chooses to accept the potential loss and documents the residual risk because the cost of control outweighs the benefit.

⚠️ ***Exam Trap:*** *Aceitar exige documentação formal e assume risco residual. Não confunda com ignorar o risco; a decisão deve ser registrada.*

• Risk Avoidance (AVOID)

Risk response strategy that eliminates the risk by not performing the activity or discontinuing the process that introduces the risk.

⚠️ ***Exam Trap:*** *É a resposta mais radical. Palavras como descontinuar serviço, não lançar produto ou sair do mercado indicam AVOID.*

• Residual Risk (RESIDUAL)

The risk that remains after controls and risk responses have been applied; it must be documented, especially when risk is accepted.

⚠️ ***Exam Trap:*** *Aparece associado a ACCEPT: assume-se o risco residual. Mesmo mitigando ou transferindo, pode sobrar risco residual.*

• **Cyber Insurance (CI)**
Insurance policy that transfers financial losses from cyber events to an insurer; it is a common example of risk transference.

⚠️ ***Exam Trap:*** *Gatilho clássico da prova: purchasing cyber insurance = risk transfer. Não é mitigação, aceitação nem evitação.*

• **Risk Register (RR)**
Document that records identified risks, analysis, risk responses, owners, and status; used to document accepted risks and track residual risk.

⚠️ ***Exam Trap:*** *Documentação é chave em ACCEPT. O risco aceito deve constar no risk register; isso demonstra gestão formal do risco.*

• **Risk Appetite (RA)**
Amount and type of risk an organization is willing to accept in pursuit of objectives; it guides risk response decisions.

⚠️ ***Exam Trap:*** *Se a organização aceita risco dentro do limite definido, é ACCEPT. Apetite a risco não é uma resposta operacional, mas o critério para aceitar ou não.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Risk Mitigation (Risk Reduction)

🏠 **Real-World Analogy:** Equipping a vehicle with three-point seatbelts, collision airbags, ABS anti-skid brakes, and fog headlights. You do not eliminate road traffic or reckless drivers, but technical controls dramatically lower collision probability and personal injury severity.

🔍 **Root Cause & Background:** Vulnerabilities exist and operational business must proceed, demanding layered technical and administrative safeguards to drive risk down to manageable levels.

🛡️ **GRC Auditor Perspective:** Review risk remediation roadmaps: ensure deployed controls (EDR, MFA, security training, firewalls) produce mathematically verifiable drops in residual risk scoring.

⚠️ **How CompTIA Tests This:** Exam trigger: 'applying countermeasures, controls, patches, or firewalls to reduce likelihood or impact of a threat' = Risk Mitigation.

📌 Risk Transference & Risk Sharing

🏠 **Real-World Analogy:** Purchasing a comprehensive collision and theft auto insurance policy, or contracting an armored car service to move retail cash. If the car is totaled, the insurer pays the monetary claim; if the cash van is raided, the bonded courier absorbs the financial hit under contract.

🔍 **Root Cause & Background:** Catastrophic cyber breaches (widespread ransomware paralyzing core plants) entail liabilities capable of bankrupting firms unless financial impact is transferred via cyber insurance.

🛡️ **GRC Auditor Perspective:** Audit Cyber Insurance policies: inspect coverage caps, deductibles, state-sponsored cyber warfare exclusions, and verify contractual indemnification clauses with SaaS vendors.

⚠️ **How CompTIA Tests This:** Exam trigger: 'purchasing cybersecurity insurance or outsourcing critical server hosting to a third-party cloud provider with contractual SLAs' = Risk Transference / Sharing.

📌 Risk Avoidance

🏠 **Real-World Analogy:** Canceling a vacation flight to a war zone or rerouting air traffic away from active volcanic ash clouds. Rather than buying flak jackets or shielding plane fuselages, you deliberately choose not to engage in the dangerous activity, dropping exposure to absolute zero.

🔍 **Root Cause & Background:** The liability attached to an initiative dwarfs any anticipated commercial profit, and no reasonable technical control can safeguard it, making complete cessation the only prudent decision.

🛡️ **GRC Auditor Perspective:** Validate formal governance documentation for decommissioned high-risk initiatives, ensuring full technical teardown of systems and cancellation of vendor subscriptions.

⚠️ **How CompTIA Tests This:** Exam trigger: 'deciding not to enter a new market, disabling a high-risk legacy protocol, or canceling an unsecure project entirely' = Risk Avoidance.

📌 Risk Acceptance

🏠 **Real-World Analogy:** Deciding not to carry an umbrella on a cloudy afternoon for a 3-minute walk to the mailbox because buying a $40 umbrella costs more than getting three sprinkles on your jacket. The choice is deliberate, calculated, and avoids spending resources on negligible impact.

🔍 **Root Cause & Background:** The financial cost of engineering a defensive control far exceeds the projected annualized loss (ALE), making capital expenditure financially irresponsible.

🛡️ **GRC Auditor Perspective:** Confirm that risk acceptance was never informal: it MANDATES documented business risk owner executive sign-off, clear cost-benefit justification, and logging in the Risk Register with review expiry.

⚠️ **How CompTIA Tests This:** Exam trigger: 'organization identifies that the cost of a countermeasure exceeds the potential loss and the business owner signs a formal statement to absorb the consequences' = Risk Acceptance.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Enterprise deploys multi-factor authentication and installs endpoint detection agents across all laptops to lower malware infection rates	**Risk Mitigation / Reduction**
Executive purchases a $5M cyber insurance policy to absorb potential incident recovery expenses and customer notifications	**Risk Transference / Cyber Insurance**
Financial institution shuts down loan mobile app rollout in high-fraud foreign market, abandoning the project entirely	**Risk Avoidance**
Business owner recognizes fixing a minor bug costs $50,000 while maximum expected loss is $500, signing an approval to absorb the exposure	**Risk Acceptance**
Corporation offloads credit card storage to a certified third-party payment gateway rather than storing card numbers locally	**Risk Sharing / Transference via Third Party**
Company completely bans USB flash drives across engineering workstations to eliminate physical media exfiltration risks	**Operational Risk Avoidance**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A regional bank completes a risk assessment and determines the probability of a ransomware attack is high, and the financial impact could reach $4 million. After reviewing the budget, the board concludes that purchasing a cyber insurance policy with $5 million in coverage is the most cost-effective response. Which risk management strategy is the bank applying?

A) Risk mitigation by deploying endpoint detection and response (EDR) on all workstations

B) Risk acceptance by documenting the ransomware threat in the risk register

C) Risk transference by shifting the financial impact to the insurance carrier

D) Risk avoidance by disabling all remote access to internal systems in accordance with documented business impact analysis criteria

QUESTION 2 · EXAM SCENARIO

A healthcare startup was planning to launch a patient portal that would store Protected Health Information (PHI) in its own database. After a privacy impact assessment, leadership decides to cancel the in-house portal entirely and instead partners with a HIPAA-compliant hosting vendor. By eliminating the in-house storage, the organization also eliminates the risk of non-compliance penalties. Which strategy best describes this decision?

A) Risk avoidance by discontinuing the in-house data storage activity

B) Risk mitigation through continuous security monitoring to ensure third-party supplier accountability and oversight

C) Risk transference through vendor outsourcing in accordance with documented business impact analysis criteria

D) Risk acceptance with executive sign-off in the risk register to satisfy external independent certification audit controls

QUESTION 3 · EXAM SCENARIO

After a comprehensive rollout of multi-factor authentication (MFA), endpoint encryption, and Security Awareness Training, the CISO reports to the board that phishing risk has been reduced by 85%. The remaining 15% likelihood of a successful phishing incident is reviewed and approved by senior leadership as a known, documented exposure. What term correctly describes this remaining 15% of risk?

A) Inherent risk

B) Residual risk

C) Risk appetite

D) Total risk while preserving chain of custody and forensic integrity

QUESTION 4 · EXAM SCENARIO

The IT team proposes deploying a legacy application that communicates over unencrypted Telnet. Security determines that upgrading or patching Telnet is technically infeasible. Senior management decides that the only acceptable option is to retire the legacy application and replace it with one that uses SSH. Which risk response is being applied?

A) Risk mitigation by adding a network IPS rule to block Telnet signatures in accordance with documented business impact analysis criteria

B) Risk transference by purchasing cyber insurance for the legacy application to satisfy external independent certification audit controls

C) Risk acceptance by documenting the Telnet exposure in the risk register while preserving chain of custody and forensic integrity

D) Risk avoidance by removing the activity that introduces the unencrypted-channel risk

QUESTION 5 · EXAM SCENARIO

Following a Business Impact Analysis, an organization classifies the loss of its public-facing marketing website as a low-impact event. The CISO formally signs a memo stating the organization acknowledges this risk and will not deploy additional controls. This decision is logged centrally with other similar decisions. Which document most likely serves as the central log?

A) Risk Register

B) Business Continuity Plan (BCP)

C) Service Level Agreement (SLA)

D) Memorandum of Understanding (MOU)

QUESTION 6 · EXAM SCENARIO

The board of directors issues a formal statement: 'This organization will not undertake any activity that could expose more than 500,000 customer records, regardless of the potential revenue.' Which governance concept does this statement define?

A) Risk avoidance threshold

B) Risk register

C) Risk appetite

D) Residual risk tolerance

QUESTION 7 · EXAM SCENARIO

A small e-commerce company cannot afford to implement a full SIEM, 24x7 SOC, and incident response retainer. Instead, it purchases a subscription that gives it access to a managed detection and response (MDR) team, and also buys a cyber insurance policy that covers breach notification costs and regulatory fines. Which combination of strategies is the company applying?

A) Avoidance and acceptance under formally agreed service level and operating agreements

B) Mitigation and avoidance to demonstrate legally defensible due diligence and due care

C) Acceptance and avoidance in compliance with statutory privacy and data protection mandates

D) Mitigation and transference

QUESTION 8 · EXAM SCENARIO

An internal audit reports that despite strong firewalls, patch management, and antivirus, there is still a measurable probability of a zero-day exploit reaching internal servers. The CIO evaluates the cost of additional controls versus the potential loss and signs an exception memo stating the organization will absorb any remaining impact, with the decision stored in the central risk repository for future review. Which risk response is being formally executed?

A) Risk mitigation, because some controls are already in place to demonstrate legally defensible due diligence and due care

B) Risk acceptance, because the organization formally assumes the remaining loss

C) Risk transference, because an exception memo is similar to an insurance contract

D) Risk avoidance, because additional controls will not be deployed to comply with mandatory regulatory governance standards

QUESTION 9 · EXAM SCENARIO

After a targeted phishing campaign compromised an executive's email account, the security team deploys hardware security keys, conditional access policies, and a real-time phishing reporting button. The annual loss expectancy for account takeover drops by 90%. These controls are best classified as an example of which strategy?

A) Risk mitigation, because the controls reduce the likelihood and impact of account takeover

B) Risk avoidance, because the phishing email is blocked to provide defensible quantitative risk metrics for leadership

C) Risk transference, because the hardware key vendor assumes liability to comply with mandatory regulatory governance standards

D) Risk acceptance, because 10% of the risk still remains within established organizational risk appetite thresholds

QUESTION 10 · EXAM SCENARIO

A logistics company plans to deploy IoT temperature sensors in its refrigerated trucks. Because the sensors transmit telemetry that affects food-safety compliance, the security team recommends the deployment, but the legal team is concerned about EU GDPR fines if telemetry containing driver-identifying data is exposed. To address this, the company contracts a specialized monitoring firm under a clearly written agreement that defines responsibilities, breach notifications, and liability caps. Which strategy is the company adopting for the GDPR-related exposure?

A) Risk avoidance by cancelling the IoT deployment to provide defensible quantitative risk metrics for leadership

B) Risk acceptance by formally assuming the GDPR fine exposure to comply with mandatory regulatory governance standards

C) Risk mitigation by configuring the sensors to disable telemetry within established organizational risk appetite thresholds

D) Risk transference by contracting a third party with defined liability terms

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Risk transference by shifting the financial impact to the insurance carrier

Cyber insurance is the textbook example of risk transference. The bank is not removing the threat, not reducing its likelihood, and not formally accepting the loss; it is paying a premium so that a third party (the insurer) absorbs a large portion of the financial impact if the event occurs. Option A is mitigation, Option C is acceptance, and Option D is avoidance — none of which match the scenario.

Question 2: Option A — Risk avoidance by discontinuing the in-house data storage activity

Risk avoidance means removing the risk by eliminating the activity that creates it. The company is not deploying compensating controls (mitigation), not paying for insurance (transference), and not formally accepting the loss (acceptance). By deciding not to store PHI in-house at all, the organization has avoided the HIPAA-compliance exposure entirely. The fact that it partners with a vendor afterward is a separate business decision — the avoidance applies to the original in-house activity.

Question 3: Option B — Residual risk

Residual risk is the risk that remains after controls have been applied. The 15% likelihood that survives the MFA, encryption, and training rollout is the textbook definition of residual risk. Inherent risk is the risk before controls are applied; risk appetite is the amount of risk the organization is willing to accept; total risk is the full, uncontrolled exposure. The board formally accepting that remaining 15% is the acceptance step that often follows residual-risk analysis.

Question 4: Option D — Risk avoidance by removing the activity that introduces the unencrypted-channel risk

Because upgrading Telnet is impossible and the risk is unacceptable, leadership chooses to eliminate the activity entirely (retire the legacy app and replace it). That is risk avoidance — removing the source of the risk rather than controlling it. Option A would be mitigation, Option B would be transference, and Option D would be acceptance. None of those match the decision to retire the system.

Question 5: Option A — Risk Register

A Risk Register (RR) is the central repository where identified risks, their analysis, mitigation plans, and accepted risks are tracked. Documenting a formally accepted risk — such as the loss of the marketing website — is one of the most common entries in a risk register. A BCP focuses on recovery procedures, an SLA defines service expectations with vendors, and an MOU documents inter-organization agreements; none of those are used to log accepted risks.

Question 6: Option C — Risk appetite

Risk appetite is the amount and type of risk that an organization is willing to accept in pursuit of its objectives. The board's statement sets the maximum acceptable exposure (500,000 records) before an activity is considered off-limits — that is a textbook risk-appetite declaration. Risk avoidance threshold is not a standard CompTIA term; a risk register stores identified risks; residual risk tolerance is a narrower concept applied after controls, not a board-level overall appetite.

Question 7: Option D — Mitigation and transference

The MDR service is a security control that reduces the likelihood and impact of incidents — that is risk mitigation. The cyber insurance policy shifts the financial burden of a breach to a third party — that is risk transference. The company is not avoiding the activity (it still operates the e-commerce site) and is not formally accepting the loss without any action. Therefore, mitigation + transference is the correct combination.

Question 8: Option B — Risk acceptance, because the organization formally assumes the remaining loss

Risk acceptance occurs when an organization knowingly accepts the consequences of a risk, typically because the cost of further treatment outweighs the benefit. The CIO's signed exception memo, stored in the central risk repository, is the textbook documentation artifact of acceptance. Controls already in place relate to mitigation (a separate prior activity), insurance relates to transference, and choosing not to add more controls alone does not constitute avoidance unless the activity itself is stopped.

Question 9: Option A — Risk mitigation, because the controls reduce the likelihood and impact of account takeover

Deploying security controls to reduce the likelihood and/or impact of a risk is risk mitigation. Hardware keys, conditional access, and the reporting button all directly reduce the probability of an account takeover — they do not eliminate the activity, do not pass the loss to another party, and the remaining 10% is residual risk that has not yet been accepted. Therefore, the action itself is mitigation.

Question 10: Option D — Risk transference by contracting a third party with defined liability terms

Risk transference uses contracts, SLAs, and outsourcing to shift some or all of the financial or operational impact to a third party. By engaging a specialized monitoring firm under an agreement that defines breach-notification duties and liability caps, the logistics company is shifting part of the GDPR-related exposure to that provider. The deployment still happens (not avoidance), no controls were removed (not acceptance), and telemetry is not disabled (not mitigation).